

RESUMEN DE COBIT 4.1

COBIT es un marco de trabajo y un conjunto de herramientas de Gobierno de Tecnología de Información (TI) que permite a la Gerencia cerrar la brecha entre los requerimientos de control, aspectos técnicos y riesgos de negocios. COBIT habilita el desarrollo de políticas claras y buenas prácticas para el control de TI a lo largo de las organizaciones [1].

COBIT fue publicado por primera vez por ITGI en abril de 1996. Su última actualización – COBIT® 4.1 hace énfasis en el cumplimiento reglamentario, ayudando a la organizaciones a incrementar el valor de TI, destacando los vínculos entre los objetivos del negocio y TI, y simplificando la implementación del marco de trabajo COBIT. Este marco de trabajo es la base para diferentes entes reguladores a nivel mundial, con la finalidad de lograr que las entidades reguladas optimicen sus inversiones de TI y administren adecuadamente sus riesgos tecnológicos.

CRITERIOS DE INFORMACIÓN DE COBIT [2]

Para satisfacer los objetivos del negocio, la información necesita adaptarse a ciertos criterios de control, los cuales son referidos en COBIT como requerimientos de información del negocio. Con base en los requerimientos más amplios de calidad, fiduciarios y de seguridad, se definieron los siguientes siete criterios de información:

1. La efectividad tiene que ver con que la información sea relevante y pertinente a los procesos del negocio, y se proporcione de una manera oportuna, correcta, consistente y utilizable.
2. La eficiencia consiste en que la información sea generada con el óptimo (más productivo y económico) uso de los recursos.
3. La confidencialidad se refiere a la protección de información sensitiva contra revelación no autorizada.
4. La integridad está relacionada con la precisión y completitud de la información, así como con su validez de acuerdo a los valores y expectativas del negocio.
5. La disponibilidad se refiere a que la información esté disponible cuando sea requerida por los procesos del negocio en cualquier momento. También concierne a la protección de los recursos y las capacidades necesarias asociadas.
6. El cumplimiento tiene que ver con acatar aquellas leyes, reglamentos y acuerdos contractuales a los cuales está sujeto el proceso de negocios, es decir, criterios de negocios impuestos externamente, así como políticas internas.
7. La confiabilidad se refiere a proporcionar la información apropiada para que la gerencia administre la entidad y ejerza sus responsabilidades fiduciarias y de gobierno.

Los recursos de TI identificados en COBIT se pueden definir como sigue [2]:

1. Las **aplicaciones** incluyen tanto sistemas de usuario automatizados como procedimientos manuales que procesan información.
2. La **información** son los datos en todas sus formas, de entrada, procesados y generados por los sistemas de información, en cualquier forma en que sean utilizados por el negocio.
3. La **infraestructura** es la tecnología y las instalaciones (hardware, sistemas operativos, sistemas de administración de base de datos, redes, multimedia, etc., así como el sitio donde se encuentran y el ambiente que los soporta) que permiten el procesamiento de las aplicaciones.
4. Las **personas** son el personal requerido para planear, organizar, adquirir, implementar, entregar, soportar, monitorear y evaluar los sistemas y los servicios

de información. Estas pueden ser internas, por outsourcing o contratadas, de acuerdo a como se requieran.

Para gobernar efectivamente TI, es importante determinar las actividades y los riesgos que requieren ser administrados. Normalmente se ordenan dentro de dominios de responsabilidad de plan, construir, ejecutar y Monitorear. COBIT define las actividades de TI en un modelo de 34 procesos genéricos agrupados en **4 dominios**:

- Planear y Organizar (PO) → Estrategias y tácticas. Identificar la manera en que TI pueda contribuir de la mejor manera al logro de los objetivos del negocio. Proporciona dirección para la entrega de soluciones (AI) y la entrega de servicio (DS).
- Adquirir e Implementar (AI) → Identificación de soluciones, desarrollo o adquisición, cambios y/o mantenimiento de sistemas existentes. Proporciona las soluciones y las pasa para convertirlas en servicios.
- Entregar y Dar Soporte (DS) → Cubre la entrega de los servicios requeridos. Incluye la prestación del servicio, la administración de la seguridad y de la continuidad, el soporte del servicio a los usuarios, la administración de los datos y de las instalaciones operacionales. Recibe las soluciones y las hace utilizables por los usuarios finales.
- Monitorear y Evaluar (ME) → Todos los procesos de TI deben evaluarse de forma regular en el tiempo en cuanto a su calidad y cumplimiento de los requerimientos de control. Este dominio abarca la administración del desempeño, el monitoreo del control interno, el cumplimiento regulatorio y la aplicación del gobierno. Monitorear todos los procesos para asegurar que se sigue la dirección provista.

Los dominios se equiparan a las áreas tradicionales de TI de planear, construir, ejecutar y monitorear.

A lo largo de estos cuatro dominios, COBIT ha identificado 34 procesos de TI generalmente usados. Mientras la mayoría de las empresas ha definido las responsabilidades de planear, construir, ejecutar y monitorear para TI, y la mayoría tienen los mismos procesos clave, pocas tienen la misma estructura de procesos o le aplicaran todos los 34 procesos de COBIT. COBIT proporciona una lista completa de procesos que puede ser utilizada para verificar que se completan las actividades y responsabilidades; sin embargo, no es necesario que apliquen todas, y, aun más, se pueden combinar como se necesite por cada empresa.

Para cada uno de estos 34 procesos, tiene un enlace a las metas de negocio y TI que soporta. Información de cómo se pueden medir las metas, también se proporcionan cuales son sus actividades clave y entregables principales, y quién es el responsable de ellas.

COBIT proporciona un modelo de procesos de referencia y un lenguaje común para que cada uno en la empresa visualice y administre las actividades de TI. La incorporación de un modelo operacional y un lenguaje común para todas las partes de un negocio involucradas en TI es uno de los pasos iniciales más importantes hacia un buen gobierno.

También brinda un marco de trabajo para la **medición y monitoreo** del desempeño de TI, comunicándose con los proveedores de servicios e integrando las mejores prácticas administrativas.

Un modelo de procesos fomenta la propiedad de los procesos, permitiendo que se definan las responsabilidades. Para gobernar efectivamente TI, es importante determinar las actividades y los riesgos que requieren ser administrados. Éstos se pueden resumir como sigue:

LOS PROCESOS REQUIEREN CONTROLES

Control → políticas, procedimientos, prácticas y estructuras organizacionales diseñadas para brindar una seguridad razonable que los objetivos de negocio se alcanzarán, y los eventos no deseados serán prevenidos o detectados y corregidos.

Objetivos de Control → requerimientos mínimos para un control efectivo de cada proceso de IT.

Gerencia usa los procesos para organizar y administrar las actividades de TI en curso.

Cada proceso de TI de COBIT tiene un objetivo de control de alto nivel y un número de objetivos de control detallados

Además de los objetivos de control detallados, cada proceso COBIT tiene requerimientos de control genéricos que se identifican con PCn, que significa número de control de proceso:

PC1 Dueño del proceso → Asignar un dueño para cada proceso COBIT de tal manera que la responsabilidad sea clara.

PC2 Reiterativo → Definir cada proceso COBIT de tal forma que sea repetitivo.

PC3 Metas y objetivos → Establecer metas y objetivos claros para cada proceso COBIT para una ejecución efectiva.

PC4 Roles y responsabilidades → Definir roles, actividades y responsabilidades claros en cada proceso COBIT para una ejecución eficiente.

PC5 → Desempeño del proceso Medir el desempeño de cada proceso COBIT en comparación con sus metas.

PC6 → Políticas, planes y procedimientos Documentar, revisar, actualizar, formalizar y comunicar a todas las partes involucradas cualquier política, plan ó procedimiento que impulse un proceso COBIT.

Los propietarios de procesos deben entender qué entradas requieren de otros procesos y que requieren otros de sus procesos.

Roles y responsabilidades documentados → Clave para un gobierno efectivo.

Gráfica **RACI** (quién es responsable, quién rinde cuentas, quién es consultado y quien informado) para cada proceso.

Rendir cuentas → la persona que provee autorización y direccionamiento a una actividad.

Responsabilidad → la persona que realiza la actividad.

Consultado e Informado → garantizan que todas las personas que son requeridas están involucradas y dan soporte al proceso.

CONTROLES DEL NEGOCIO Y CONTROLES DE TI

- **Objetivos de negocio** → Se fijan a nivel de dirección ejecutiva. Se establecen políticas y se toman decisiones de cómo aplicar y administrar los recursos empresariales para ejecutar la estrategia de la compañía.
Los controles TI se guían por este conjunto de objetivos y políticas de alto nivel.
- **Controles de negocio** → a nivel de procesos de negocio. Son controles para actividades específicas del negocio. La mayoría de los procesos de negocio están automatizados e integrados con los sistemas aplicativos de TI → muchos de los controles a este nivel estén automatizados [**controles de las aplicaciones**].
P.e.: Integridad, precisión, validez, autorización, segregación de funciones...
Otros controles como procedimientos manuales (autorización de transacciones, separación de funciones conciliaciones manuales...) [**controles manuales**].

- **Servicios TI**→ Proporcionados para soportar los procesos de negocio. Suelen estar compartidos por varios procesos de negocio. A estos servicios se también aplican controles **[controles generales de TI]**. P.e.: desarrollo de sistemas, administración de cambios, seguridad, operaciones del computador, ...

Conjunto recomendado de controles de las aplicaciones:

Controles de origen de datos/ autorización

AC1 Procedimientos de preparación de datos
 AC2 Procedimientos de autorización de documentos fuente
 AC3 Recolección de datos de documentos fuente
 AC4 Manejo de errores en documentos fuente
 AC5 Retención de documentos fuente

Controles de entrada de datos

AC6 Procedimientos de autorización de captura de datos
 AC7 Verificaciones de precisión, integridad y autorización
 AC8 Manejo de errores en la entrada de datos

Controles en el Procesamiento de datos

AC9 Integridad en el procesamiento de datos
 AC10 Validación y edición del procesamiento de datos
 AC11 Manejo de errores en el procesamiento de datos

Controles de salida de datos

AC12 Manejo y retención de salidas
 AC13 Distribución de salidas
 AC14 Cuadre y conciliación de salidas
 AC15 Revisión de salidas y manejo de errores
 AC16 Provisión de seguridad para reportes de salida

Controles de límites

AC17 Autenticidad e integridad
 AC18 Protección de información sensitiva durante su transmisión y transporte

GENERADORES DE MEDICIONES

Las empresas deben medir dónde se encuentran y dónde se requieren mejoras, e implementar un juego de herramientas gerenciales para monitorear esta mejora. ¿Hasta dónde debemos ir? ¿Está justificado el costo por el beneficio?

Para responder a esto COBIT utiliza:

- **Modelos de madurez** que facilitan la evaluación por medio de benchmarking y la identificación de las mejoras necesarias en la capacidad
- **Metas y mediciones** de desempeño para los procesos de TI→ cómo los procesos satisfacen las necesidades del negocio y de TI, y cómo se usan para medir el desempeño de los procesos internos
- **Metas de actividades** para facilitar el desempeño efectivo de los procesos

Usando los procesos de madurez desarrollados para cada uno de los 34 procesos TI la administración podrá identificar:

- El desempeño real de la empresa—Dónde se encuentra la empresa hoy (●)
- El estatus actual de la industria—La comparación (↑)
- El objetivo de mejora de la empresa—Dónde desea estar la empresa (★)

Modelo genérico de madurez

0 No existente. Carencia completa de cualquier proceso reconocible. La empresa no ha reconocido siquiera que existe un problema a resolver.

1 Inicial. Existe evidencia que la empresa ha reconocido que los problemas existen y requieren ser resueltos. Sin embargo; no existen procesos estándar en su lugar existen

enfoques *ad hoc* que tienden a ser aplicados de forma individual o caso por caso. El enfoque general hacia la administración es desorganizado.

2 Repetible. Se han desarrollado los procesos hasta el punto en que se siguen procedimientos similares en diferentes áreas que realizan la misma tarea. No hay entrenamiento o comunicación formal de los procedimientos estándar, y se deja la responsabilidad al individuo. Existe un alto grado de confianza en el conocimiento de los individuos y, por lo tanto, los errores son muy probables.

3 Definido. Los procedimientos se han estandarizado y documentado, y se han difundido a través de entrenamiento. Sin embargo, se deja que el individuo decida utilizar estos procesos, y es poco probable que se detecten desviaciones. Los procedimientos en sí no son sofisticados pero formalizan las prácticas existentes.

4 Administrado. Es posible monitorear y medir el cumplimiento de los procedimientos y tomar medidas cuando los procesos no estén trabajando de forma efectiva. Los procesos están bajo constante mejora y proporcionan buenas prácticas. Se usa la automatización y herramientas de una manera limitada o fragmentada.

5 Optimizado. Los procesos se han refinado hasta un nivel de mejor práctica, se basan en los resultados de **mejoras continuas** y en un modelo de madurez con otras empresas. TI se usa de forma integrada para automatizar el flujo de trabajo, brindando herramientas para mejorar la calidad y la efectividad, haciendo que la empresa se adapte de manera rápida.

MEDICIÓN DEL DESEMPEÑO

Se definen **metas** a nivel de Negocio, TI, Proceso y Actividad

Se definen **métricas** a nivel de negocio, de TI y de proceso.

Se utilizan dos tipos de métrica:

- Indicadores clave de metas (KGI) → indican (después del hecho) si un proceso ha alcanzado o no sus requerimientos de negocio.
- Indicadores clave de desempeño (KPI) → indican cómo se está desempeñando un proceso (si será factible o no alcanzar la meta).

Los indicadores de metas de bajo nivel se convierten en indicadores de desempeño para los niveles altos.

Metas de actividad	Metas de Proceso	Metas de TI	Metas de Negocio
		KPI	Métrica de Negocio KGI
	KPI	Métrica de TI KGI	
KPI	Métrica de Proceso KGI		

Características de métricas efectivas:

- Una alta proporción entendimiento-esfuerzo (esto es, el entendimiento del desempeño y del logro de las metas en contraste con el esfuerzo de lograrlos)
- Deben ser comparables internamente (esto es, un porcentaje en contraste con una base o números en el tiempo)
- Deben ser comparables externamente sin tomar en cuenta el tamaño de la empresa o la industria
- Es mejor tener pocas métricas (quizá una sola muy buena que pueda ser influenciada por distintos medios) que una lista más larga de menor calidad
- Debe ser fácil de medir y no se debe confundir con las metas

MARCO DE TRABAJO GENERAL DE COBIT:

El modelo de procesos de COBIT compuesto de 4 dominios que contienen 34 procesos genéricos (mas detalles en [3]), administrando los **recursos** de TI para proporcionar **información** al negocio de acuerdo con los requerimientos del negocio y de gobierno.

MONITOREAR Y EVALUAR

- ME1 Monitorear y evaluar el desempeño de TI.
- ME2 Monitorear y evaluar el control interno
- ME3 Garantizar cumplimiento regulatorio.
- ME4 Proporcionar gobierno de TI.

PLANEAR Y ORGANIZAR

- PO1 Definir el plan estratégico de TI.
- PO2 Definir la arquitectura de la información
- PO3 Determinar la dirección tecnológica.
- PO4 Definir procesos, organización y relaciones de TI.
- PO5 Administrar la inversión en TI.
- PO6 Comunicar las aspiraciones y la dirección de la gerencia.
- PO7 Administrar recursos humanos de TI.
- PO8 Administrar calidad.
- PO9 Evaluar y administrar riesgos de TI
- PO10 Administrar proyectos.

ADQUIRIR E IMPLANTAR

- AI1 Identificar soluciones automatizadas.
- AI2 Adquirir y mantener el software aplicativo.
- AI3 Adquirir y mantener la infraestructura tecnológica
- AI4 Facilitar la operación y el uso.
- AI5 Adquirir recursos de TI.
- AI6 Administrar cambios.
- AI7 Instalar y acreditar soluciones y cambios.

INFORMACIÓN

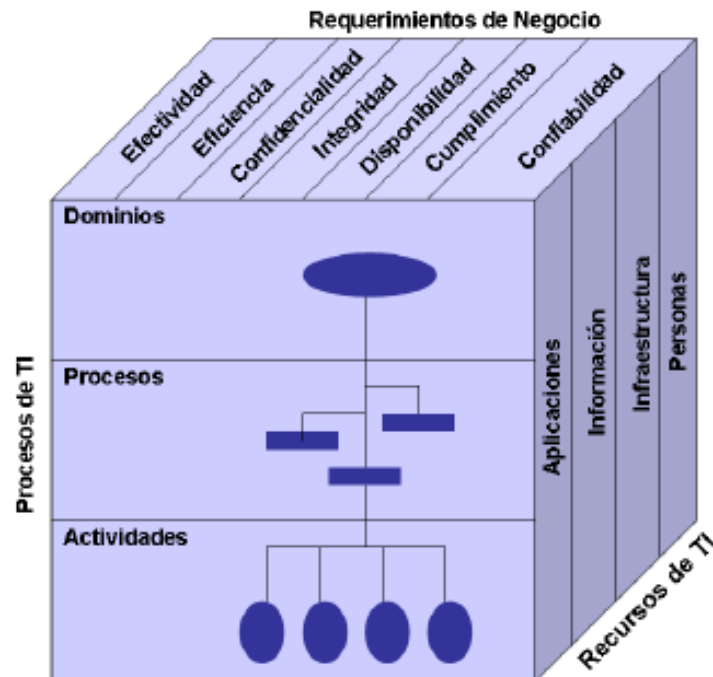
Efectividad
Eficiencia
Confidencialidad
Integridad
Disponibilidad
Cumplimiento
Confiabilidad

ENTREGAR Y DAR SOPORTE

- DS1 Definir y administrar niveles de servicio.
- DS2 Administrar servicios de terceros.
- DS3 Administrar desempeño y capacidad.
- DS4 Garantizar la continuidad del servicio.
- DS5 Garantizar la seguridad de los sistemas.
- DS6 Identificar y asignar costos.
- DS7 Educar y entrenar a los usuarios.
- DS8 Administrar la mesa de servicio y los incidentes.
- DS9 Administrar la configuración.
- DS10 Administrar los problemas.
- DS11 Administrar los datos.
- DS12 Administrar el ambiente físico.
- DS13 Administrar las operaciones.

RECURSOS

Aplicaciones
Información
Infraestructura
Personas

FIG 1. El Cubo de COBIT [2, p.25]

REFERENCIAS

- [1] ITSOR_Consulting. (nd). *Curso COBIT 4.1*. Retrieved Sept., 2009, from the World Wide Web: http://www.itsor.net/pdf/ITSOR_COBIT_Brochure_VE.pdf
- [2] ISACA. (2007). *COBIT 4.1 en Español*. IT Governance Institute. Retrieved Sept., 2009, from the World Wide Web: http://www.isaca.org/Content/NavigationMenu/Members_and_Leaders1/COBIT6/Obtain_COBIT/cobiT4.1spanish.pdf
- [3] Rojas-Córsico, I. S. (nd). *Trabajo de Auditoria: Normas COBIT*. Retrieved Sept., 2009, from the World Wide Web: <http://www.monografias.com/trabajos14/auditoriasistemas/auditoriasistemas.shtml>